Testes Finais

Portal PIBIC — UNICAP · Carga, estresse, segurança e smoke
Executados em 12/11/2026 sobre a `main` (commit `5242513`) · Equipe: Ana Pellegrino, Artur Uchôa, André Mota, Henrique Valença, Pedro Mendes

1. Resumo

Etapa	Situação encontrada	Problemas	Depois das correções
Carga	0% de falhas até 100 conexões, mas o login fazia só 10,5/s (mediana de 887 ms)	Hash de senha lento, travando o servidor	0% de falhas; login a 55,5/s (mediana de 175 ms)
Estresse	Sem falhas até 1.600 conexões; quebra em ~2.400; recupera em ~10 s	Logins simultâneos travavam todas as rotas; com o banco fora, requisições penduradas	Rota leve com p99 de 2.286 → 6 a 11 ms durante logins; banco fora: 503 em 3 s (saúde) ou 25 s
Segurança	47 de 51 verificações	Força bruta paralela, bloqueio coletivo por IP, amplificação de memória (Zod), dependências vulneráveis, mensagem do 413	51 de 52 (a restante é risco aceito)
Smoke	—	Testes E2E tentavam enviar e-mail real e travavam	31 de 31 passos + todas as suítes do projeto verdes

Foram corrigidos **9 pontos**, todos cobertos por testes automatizados (o servidor passou de 173 para 187 testes).

2. O que foi feito

Os testes seguiram a ordem pedida: **carga** → **estresse** → **segurança** → **correções** → **smoke**. Depois das correções, carga, estresse e segurança foram **repetidos** para comprovar cada correção.

> **Carga e estresse foram feitos só localmente.** Contra a Vercel, uma rajada aciona o firewall anti-DDoS da plataforma (o IP de quem testa passa a receber uma página de verificação) e consome a cota diária do Firestore gratuito. Os scripts recusam qualquer endereço que não seja `localhost`.

Item	Configuração
Máquina	AMD Ryzen 7 5825U (8 núcleos/16 threads), 15 GB de RAM, Windows 11
API	Build de produção (`node dist/index.js`), porta 3100
Banco	Emulador do Firestore (Java 21), com o seed de demonstração
Gerador de carga	`autocannon` 8.0.0, na mesma máquina
E-mail	SMTP desligado nos testes: nenhum e-mail real enviado
Scripts	Pasta `testes-finais/` : `carga.mjs` , `estresse.mjs` , `queda-do-banco.mjs` , `seguranca.mjs` , `smoke.mjs`

Limitações: o emulador não reproduz o desempenho do Firestore real e o gerador de carga divide a CPU com a API. Os números servem para comparar antes e depois e achar gargalos, não para prever a capacidade em produção (na Vercel, a API

escala em várias instâncias). Uma "conexão" faz requisições sem pausa; uma pessoa real lê a tela entre cliques, então 100 conexões equivalem a bem mais de 100 pessoas.

3. Etapa 1 — Teste de carga

Velocidade, estabilidade e tempo de resposta em uso normal (10 conexões) e com muitos usuários simultâneos (50 e 100).

3.1 Linha de base por rota (10 conexões, 10 s cada) — tempos em ms

Rota	Antes req/s	p50	p99	Depois req/s	p50	p99	Falhas
Site	2.565,4	3	7	4.010,8	2	4	0%
Saúde + banco	648,3	14	31	792,9	11	23	0%
Editais abertos	310,6	31	54	426,7	22	41	0%
Projetos com vaga	196,8	49	84	276,7	34	64	0%
Vitrine de pesquisas	246,4	39	66	344,6	28	47	0%
Sessão /me	771,3	12	23	855,5	10	26	0%
Notificações não lidas	460,7	20	37	495,2	19	35	0%
Minhas candidaturas	171,5	56	89	192,6	50	73	0%
Meus projetos	195,4	49	78	225,6	43	64	0%
Minhas avaliações	118,8	69	464	190,5	51	71	0%
Painel do gestor	140,3	68	112	191,7	50	73	0%
Triagem	114	84	131	151,2	64	97	0%
Login	**10,5**	**887**	**1.484**	**55,5**	**175**	**303**	0%

Nenhuma falha, antes e depois. **Só o login mudou por causa do código** (troca do hash de senha, correção C1). As demais rotas não foram alteradas; a diferença nelas é variação entre rodadas (a primeira pegou o emulador "frio").

3.2 Uso misto (todos os perfis intercalados, 20 s por nível) — tempos em ms

Conexões	Antes req/s	p50	p99	Depois req/s	p50	p99	Falhas (antes/depois)
10	247,6	38	88	301,1	32	70	0% / 0%
50	162,2	199	2.420	337,8	145	290	0% / 0%
100	129	545	3.682	287,8	330	739	0% / 0%

Com 100 conexões, nem a API (59% de um núcleo) nem o banco (20%) chegaram ao limite de CPU: a latência maior vem da fila de leituras no banco. Parte da melhora entre as rodadas é variação (no estresse, o mesmo cenário deu p99 parecido antes e depois).

Problema encontrado: o login usava `bcryptjs`, que calcula o hash em JavaScript na thread principal do Node: 10,5 logins/s e mediana de 887 ms com só 10 pessoas entrando ao mesmo tempo.

4. Etapa 2 — Teste de estresse

Levar o sistema ao limite de acessos e à falta de recursos, achar o ponto de quebra e ver como ele se recupera.

4.1 Rampa até a quebra (critério: falhas > 5% ou p99 > 10 s) — tempos em ms

Antes das correções

Conexões	req/s	p50	p99	Falhas
10 (ref.)	269,6	38	69	0%
50	305,4	172	272	0%
100	251,8	388	1.344	0%
200	261,5	773	1.461	0%
400	249,6	1.455	2.680	0%
800	227,9	2.981	5.205	0%
1600	329,2	5.423	7.925	0%
2400	36,4	6.490	7.614	137,7% ← quebra

Depois das correções

Conexões	req/s	p50	p99	Falhas
10 (ref.)	206,5	47	115	0%
50	265,9	188	373	0%
100	229,8	436	842	0%
200	252,5	803	1.461	0%
400	229,1	1.681	2.935	0%
800	213,6	3.295	5.532	0%
1600	235,7	6.598	8.467	0%
2400	22,8	8.940	9.603	96,3% ← quebra

- **Capacidade:** ~250 req/s num único processo local; acima disso, mais usuários só aumentam a fila.
- **Degrada sem falhar** até 1.600 conexões simultâneas: todas as respostas foram 200, só mais lentas.
- **Ponto de quebra (~2.400 conexões):** a fila de conexões do sistema operacional transborda (`ETIMEDOUT`). Não há erro da API.
- **Recuperação:** volta ao normal em ~10 s após o pico, sozinha (antes: ~10 s).

4.2 Tempestade de logins, medindo ao mesmo tempo uma rota leve (`/api/health`)

Medida	Antes	Depois
Logins por segundo	9,5	47,1 a 57
Mediana do login (ms)	2.480	523 a 628
Falhas	0%	0%
/api/health durante os logins — p99 (ms)	**2.286**	**6 a 11**
/api/health durante os logins — req/s	63,5 (sozinha: 5.017,5)	2.037,6 a 3.182

"Antes": 30 logins simultâneos numa conta. "Depois": 30 logins em 10 contas diferentes (3 por conta), como num início de turno no campus — com o novo limite por conta, 30 logins simultâneos numa conta só são tratados como ataque. O custo do hash é o mesmo nos dois cenários. "Depois" traz a menor e a maior de duas rodadas.

Problema encontrado: durante uma rajada de logins, **todas as outras requisições ficavam paradas** (rota que não faz nada: p99 de 5 ms → 2.286 ms). Na Vercel, várias requisições dividem a mesma instância, então o efeito seria o mesmo.

4.3 Falta de recursos

Corpo gigante (2 MB de JSON em rajada): 2.264 respostas 413, nenhum erro, servidor saudável depois. A mensagem dizia "Arquivo acima do limite de 10 MB" para um JSON (corrigido).

Queda do banco com o sistema no ar (emulador derrubado por ~20 s e religado):

Rota	Antes	Depois
`/api/health` (processo vivo)	200 o tempo todo	200 o tempo todo
`/api/health/ready` (banco ok?)	**Pendurada, sem resposta**	**503 "banco indisponível" em 3 s**
Rotas que usam o banco	**Penduradas até o banco voltar**	**503 em JSON em 25 s, com mensagem amigável**
Banco de volta	Tudo volta sozinho	Tudo volta sozinho em menos de 1 s

Problema encontrado: o cliente do Firestore fica tentando reconectar e não desiste. O usuário ficaria com a tela carregando até a Vercel derrubar a função aos 30 s, e o `/api/health/ready`, que existe para avisar "banco fora", não respondia.

5. Etapa 3 — Teste de segurança

52 verificações automatizadas contra a API local (lista completa no Anexo A), mais auditoria de dependências (`npm audit`), busca de segredos no histórico do Git e checagem das regras do Firestore de produção.

5.1 Já protegido (passou de primeira)

- **Autenticação:** rotas protegidas recusam acesso sem token; JWT com `alg: none`, segredo errado ou expirado é recusado; papel "GESTOR" forjado no token não dá acesso (o papel vem do banco); troca de senha derruba as sessões antigas.
- **Autorização:** aluno, professor e visitante recebem 403 nas rotas de gestor; ninguém lê projeto, parecer, candidatura, notificação, currículo ou relatório de outra pessoa (404, sem revelar que existe).
- **Entradas e arquivos:** cadastro não aceita papel GESTOR, campos extras nem domínio de fora; arquivo que não é PDF é recusado pela assinatura `%PDF-`; path traversal e links adulterados são recusados.
- **Produção:** leitura anônima direta no Firestore é recusada (as regras de segurança estão publicadas); nenhum segredo no histórico do Git; HSTS ativo.

5.2 Problemas encontrados

#	Severidade	Problema
S1	**Alta**	**Força bruta por concorrência:** 30 senhas em paralelo eram todas testadas, apesar do limite de 10 (o contador era consultado antes e somado só depois do hash).
S2	**Alta**	**Bloqueio coletivo:** 10 senhas erradas em qualquer conta bloqueavam o login de todos no mesmo IP. No Wi-Fi do campus, um aluno tiraria o acesso de todo mundo por 15 min. O mesmo valia para "esqueci a senha", cadastro (20/h, menos que uma turma) e troca de senha.
S3	**Alta**	**Amplificação de memória (Zod 3, GHSA-mrhx-c7xc-m3w5):** uma lista de 500 mil itens (~1 MB) enviada por qualquer professor gerava resposta de 17 MB e subia a memória da API de 135 para 522 MB.
S4	**Alta**	**Dependências:** `body-parser` < 1.20.9 (negação de serviço), `qs` e outras com falhas conhecidas.
S5	**Baixa**	O 413 dizia "Arquivo acima do limite de 10 MB" para qualquer JSON grande.
S6	**Baixa**	Cadastro com e-mail já usado revela que a conta existe (risco aceito, seção 8).

5.3 Depois das correções

Verificação	Antes	Depois
30 senhas erradas em paralelo	**30 testadas**	**0 testadas**, todas bloqueadas
Senhas erradas em sequência	bloqueio após 10	**exatamente 10 testadas**, depois bloqueio (mesmo com a senha certa)
Outra pessoa da mesma rede, com a senha certa	**429 (bloqueada)**	**200 (entra)**
"Esqueci a senha" para o mesmo e-mail	limite por IP (rede inteira)	**limite por e-mail** (3 em 15 min)
Lista de 500 mil itens	**17 MB de resposta, +390 MB de memória**	**400 com menos de 5 KB, em menos de 2 s**
Total	**47 de 51**	**51 de 52**

6. Etapa 4 — Correções implementadas e motivos

#	Modificação	Motivo (achado)	Arquivos
C1	**`bcrypt` nativo** no lugar do `bcryptjs`: o hash roda no pool de threads do Node, fora da thread principal. Hashes já gravados continuam valendo, sem migração.	Login lento e servidor travado em rajadas de login (carga 3.1, estresse 4.2)	`auth.service.ts`, `seed.ts`, `package.json`
C2	**Prazo nas requisições:** `/api/health/ready` responde 503 em 3 s; qualquer rota responde 503 em JSON em 25 s (abaixo dos 30 s da Vercel). O tratador de erros ignora erros que chegam depois da resposta.	Requisições penduradas com o banco fora (estresse 4.3)	`http.middleware.ts`, `app.container.ts`
C3	**Limite de tentativas reescrito:** a tentativa é reservada antes de a rota rodar (soma atômica) e devolvida se o login der certo ou se for recusada.	Força bruta paralela furava o limite (S1)	`security.middleware.ts`
C4	**Limites por conta:** login por IP + e-mail (10 erros/15 min) com teto de 100 por IP; "esqueci a senha" e "reenviar link" por e-mail (3/15 min) com teto de 30 por IP; troca de senha por sessão; cadastro de 20 para 60/h por rede.	Bloqueio coletivo no Wi-Fi do campus (S2)	`app.container.ts`
C5	**Contador no Firestore sem transação:** um documento por janela de 15 min e incremento atômico nativo; o contador por IP só lê quando o login dá certo.	Regressão da 1ª versão de C3, pega pelo reteste (ver abaixo)	`firestore.rate-limit.store.ts`
C6	**Listas limitadas antes da validação** (`listaLimitada`) nas 5 listas que vêm do usuário (teto de 200 cotas por edital) e no máximo 20 erros de validação na resposta.	Amplificação de memória pelo Zod (S3)	`lista.ts`, DTOs, `http.middleware.ts`
C7	**`npm audit fix`** (só atualizações compatíveis): `body-parser` 1.20.9, `qs` 6.16.2 e dependências de desenvolvimento do front.	Dependências vulneráveis (S4)	`package-lock.json`
C8	**Mensagem do 413 conforme o tipo:** "Arquivo acima do limite de 10 MB" para PDF; "Dados enviados acima do tamanho permitido" para JSON.	Mensagem enganosa (S5)	`http.middleware.ts`
C9	**Testes nunca enviam e-mail real:** E2E de API e servidor do Playwright forçam o SMTP vazio e o banco no emulador.	Com o Gmail no `.env`, os E2E tentavam enviar e-mail real e o Jest não encerrava (suíte travada por mais de 20 min)	`setup-env.js`, `playwright.config.ts`

Uma regressão pega pelos próprios testes. A primeira versão de C3 usava uma *transação* do Firestore para somar a tentativa. No reteste de estresse, um login certo passou a levar **12,5 s** e o log mostrou `Transaction lock timeout`: logins simultâneos do mesmo IP disputavam o mesmo documento, e, ao expirar, o limitador liberava a requisição. No Firestore real, a rajada voltaria a furar o limite. A versão final (C5) não usa transação; o estresse seguinte não registrou nenhum aviso do limitador.

Testes automatizados novos

- **Integração:** rajada paralela testa no máximo 10 senhas e depois bloqueia; bloqueio de uma conta não impede outra pessoa da mesma rede; "esqueci a senha" limitado por e-mail; 413 com a mensagem certa;

lista de 500 mil itens recusada em menos de 2 s.

- **Unidade:** `listaLimitada`, `comPrazo`, `prazoDaRequisicao` e o contador em memória.
- **E2E no Firestore:** 30 somas simultâneas no mesmo contador, sem perda nem trava.

7. Etapa 5 — Smoke test da versão nova

Suíte	Onde roda	Resultado
Typecheck e ESLint (server e web)	local	✓ sem erros e sem avisos
Unidade + integração do servidor	memória	✓ 187 de 187
Unidade do front (Vitest)	local	✓ 7 de 7
Integração do servidor no Firestore	emulador	✓ 96 de 96
E2E de API (jornadas do gestor, concorrência)	emulador	✓ 7 de 7
E2E no navegador (Playwright, Chromium)	emulador + build completa	✓ 3 de 3: ciclo completo (edital, divulgação, candidatura, seleção, três pareceres, homologação e relatório mensal); rotas protegidas por papel; 404 público sem violação de CSP
Roteiro de smoke (`smoke.mjs`)	build completa	✓ 31 de 31 passos (Anexo B)

Depois do deploy: `node testes-finais/smoke.mjs --url=https://SEU-PROJETO.vercel.app` faz só leituras públicas (uma dúzia de requisições, nada é gravado).

8. Riscos aceitos e pendências

Item	Decisão
Enumeração pelo cadastro (S6)	**Aceito.** Só e-mails @unicap.br se cadastram (já públicos na instituição), há limite por rede, e esconder a resposta pioraria a vida de quem esqueceu que tem conta.
Zod 3 e React Router 6 (`npm audit`)	**Mitigados, sem migração agora.** As correções exigem versões maiores. O vetor do Zod foi fechado por C6; o do React Router não se aplica (o redirecionamento só aceita caminhos internos). A migração vai para o backlog.
Contas de demonstração em produção	**Pendente — decisão da equipe.** A produção tem as contas do seed antigo (ex.: `gestor@pibic.edu.br`), com senhas publicadas no repositório público (login de gestor confirmado em 29/10). Trocar a senha ou excluir antes do uso real.
Segredos fora do cofre	**Pendente.** Segredos de produção circularam em conversas e capturas de tela durante a configuração do deploy. Gerar novos `JWT_SECRET`, `CRON_SECRET`, senha de app do Gmail e chave do Firebase, e atualizar na Vercel.

Anexo A — Verificações de segurança (resultado final: 51 de 52)

Id	Grupo	Verificação	Esperado	Obtido	
A1	Autenticação	17 rotas protegidas sem token	todas 401	todas 401	✓
A2	Autenticação	Token malformado	401	401	✓
A3	Autenticação	JWT com alg "none" se passando pelo gestor	401	401	✓
A4	Autenticação	JWT de gestor assinado com segredo errado	401	401	✓
A5	Autenticação	JWT expirado (assinatura válida)	401	401	✓
A6	Autenticação	JWT válido de aluno com papel GESTOR no token (papel vem do banco)	403	403	✓
A7	Autenticação	JWT válido de usuário inexistente	401	401	✓
A8	Autenticação	Login de conta com e-mail não confirmado	403 EMAIL_NAO_CONFIRMADO	403 EMAIL_NAO_CONFIRMADO	✓
E1	Links por e-mail	Link de confirmação usado duas vezes	1º 200, 2º 400	200, 400	✓
E2	Links por e-mail	Nome com HTML escapado no e-mail enviado	sem <img no HTML	escapado	✓
A9	Autenticação	Troca de senha derruba a sessão antiga	antiga 401	troca 200, antiga 401	✓
E3	Links por e-mail	"Esqueci minha senha" não revela se o e-mail tem conta	respostas iguais	iguais	✓
E4	Links por e-mail	Token de nova senha adulterado	400	400	✓
E5	Links por e-mail	Token de nova senha usado duas vezes	1º 200, 2º 400	200, 400	✓
E6	Links por e-mail	Login não revela se o e-mail tem conta	mesma resposta	iguais	✓
E7	Links por e-mail	Cadastro com e-mail já usado revela que a conta existe	não revelar (ou risco aceito)	409 "Já existe uma conta com este e-mail."	risco aceito
B1	Autorização	discente em 7 rotas de gestor	todas 403	todas 403	✓
B2	Autorização	docente em 7 rotas de gestor	todas 403	todas 403	✓
B3	Autorização	visitante em 7 rotas de gestor	todas 403	todas 403	✓
B4	Autorização	Aluno tenta se promover a gestor	403	403	✓
B5	Autorização	Aluno lê projeto em avaliação de um professor	404	404	✓

Id	Grupo	Verificação	Esperado	Obtido	
B6	Autorização	Professor sem vínculo lê projeto em avaliação de colega	404	404	✓
B7	Autorização	Controle: avaliador indicado lê o projeto que avalia	200	200	✓
B8	Autorização	Professor edita projeto de colega	403/404	404	✓
B9	Autorização	Aluna cancela a candidatura de outro aluno	403/404	404	✓
B10	Autorização	Aluno marca como lida a notificação de outro	403/404	404	✓
B11	Autorização	Professor lê o parecer de outro avaliador	403/404	404	✓
B12	Autorização	Aluno lê o projeto (e relatórios) de outro bolsista	403/404	404	✓
B13	Autorização	Aluna baixa o currículo de outro candidato	403/404	403	✓
B14	Autorização	Professor lista candidatos do projeto de colega	403/404	404	✓
C1	Entradas	Cadastro pedindo papel GESTOR	400	400	✓
C2	Entradas	Cadastro com campo extra (emailPendente:false)	400	400	✓
C3	Entradas	Cadastro com domínio de fora (3 variações)	todas 400	400,400,400	✓
C4	Entradas	Operadores e objetos na query string	nenhum 500	200,200,200	✓
C5	Entradas	JSON malformado	400 sem stack	400	✓
C6	Entradas	Rota inexistente da API	404 JSON	404 JSON	✓
C7	Entradas	Corpo JSON de 2 MB	413	413 "Dados enviados acima do tamanho permitido."	✓
C8	Entradas	Mensagem do 413 adequada a corpo JSON	sem citar "Arquivo"	Dados enviados acima do tamanho permitido.	✓
C9	Entradas	Senha fraca (só números)	400	400	✓
D1	Arquivos	Arquivo que não é PDF com Content-Type de PDF	400	400 "Formato inválido. Apenas arquivos PDF são aceitos."	✓
D2	Arquivos	Envio com assinatura do link adulterada	403	403	✓
D3	Arquivos	Path traversal na chave do arquivo	400/404	400,400	✓
D4	Arquivos	Aluno registra como seu um arquivo enviado por outra aluna	400	400	✓
D5	Arquivos	Link de leitura com o nome do arquivo trocado	403	403	✓

Id	Grupo	Verificação	Esperado	Obtido	
F1	Configuração	Cabeçalhos de segurança da API	todos presentes	todos presentes	✓
F2	Configuração	X-Powered-By (revela Express)	ausente	ausente	✓
F3	Configuração	CORS para origem maliciosa	sem Access-Control-Allow-Origin	ausente	✓
F4	Configuração	Tarefas agendadas sem / com segredo errado / certo	401, 401, 200	401, 401, 200	✓
G1	Força bruta	30 senhas erradas em paralelo para uma conta (limite: 10)	no máximo 10 testadas	0 testadas, 30 bloqueadas	✓
G2	Força bruta	Após 10 senhas erradas, a conta atacada fica bloqueada (mesmo com a senha certa)	429, com no máximo 10 testadas	429, 10 testadas no total	✓
G3	Força bruta	Outra pessoa na mesma rede (IP) consegue entrar com a senha certa	200	200	✓
G4	Força bruta	Rajada de "esqueci minha senha" para um mesmo e-mail	bloqueia	202,202,202,429	✓

Anexo B — Roteiro de smoke (resultado final: 31 de 31)

Área	Passo	Resultado
Site	Página inicial carrega o app	✓ 97 ms
Site	Rota da SPA /login	✓
Site	Rota da SPA /cadastro	✓
Site	Rota da SPA /editais	✓
Site	Rota da SPA /pesquisas	✓
Saúde	API e banco prontos	✓ banco ok, 26 ms
Público	Editais abertos	✓ 1 edital(is)
Público	Detalhe do edital	✓
Público	Projetos com vaga	✓ 1 projeto(s)
Público	Vitrine de pesquisas	✓ 1 pesquisa(s), sem dados pessoais
Público	Áreas do CNPq	✓
Segurança	Área logada exige login	✓
Segurança	Rota inexistente responde JSON	✓
Gestor	Painel com indicadores	✓
Gestor	Gestão de editais	✓
Gestor	Central de triagem	✓
Gestor	Gestão de usuários	✓
Gestor	Auditoria	✓
Gestor	Projetos em andamento	✓
Gestor	Exportação CSV	✓
Professor	Meus projetos	✓ 2 projeto(s)
Professor	Candidatos do projeto divulgado	✓ 2 candidato(s), Lattes acessível
Professor	Minhas avaliações	✓
Professor	Lista de professores para indicar	✓
Aluno	Minhas candidaturas	✓
Aluno	Meu projeto de bolsa	✓
Aluno	Notificações	✓
Aluno	Currículo Lattes no perfil	✓
Visitante	Sessão ativa	✓
Visitante	Sem acesso à gestão	✓
Cadastro	Cria conta @unicap.br, confirma pelo link e entra	✓